ActARion

WHITEPAPER · AR EN AI BEVEILIGING

IT- en securitydossier: AR en AI op de werkvloer

Wat IT/OT, de CISO en de FG moeten beoordelen voordat digitale en AR-werkinstructies live gaan: devices, netwerk, identiteit, data, AVG, EU AI Act en NIS2



13 min lezen · november 2026

IN HET KORT

AR- en AI-werkinstructies zijn veilig in te zetten als u ze behandelt als elke andere operationele applicatie: beheerde devices, een netwerksegment zonder route naar OT, SSO met rolgebaseerde rechten, minimale en vastgelegde dataverzameling, een DPIA, tijdige betrokkenheid van de OR, hosting in de EU en menselijke controle van elke door AI opgestelde instructie.

Voor: IT/OT-managers, CISO's, functionarissen gegevensbescherming en OR-contactpersonen in de maakindustrie

BELANGRIJKSTE INZICHTEN

01 Behandel tablets, telefoons en headsets als beheerde endpoints: MDM, kioskmodus of gedeeld gebruik, wissen op afstand en gecontroleerde updates.

02 Houd het instructieplatform buiten de OT-besturingszone; operators hebben content nodig, geen toegang tot PLC's of SCADA.

03 Foto's, video en staplogs zijn persoonsgegevens zodra ze herleidbaar zijn tot een medewerker. Voer een DPIA uit en vraag instemming van de OR voordat de pilot start.

04 Onder de EU AI Act zijn door AI opgestelde werkinstructies doorgaans niet hoog-risico, maar menselijke controle, herleidbaarheid en AI-geletterdheid zijn verstandig vanaf dag één.

Inhoud

01 Waarom moeten IT en security vóór de eerste pilot aan tafel?

02 Hoe beheert u tablets, telefoons en AR-headsets?

03 Hoe sluit u AR aan op het netwerk zonder OT te raken?

04 Welke data wordt opgeslagen en wat vraagt de AVG?

05 Wat betekent de EU AI Act voor werkinstructies die AI opstelt?

06 Is NIS2 van toepassing, en hoe passen identiteit en SSO erin?

07 Welke vragen horen in de securityvragenlijst voor leveranciers?

01 HOOFDSTUK 1

Waarom moeten IT en security vóór de eerste pilot aan tafel?

Omdat AR en AI op de werkvloer tegelijk devices, netwerken, identiteiten en persoonsgegevens raken. Wie IT/OT, de CISO en de FG vanaf het begin betrekt, voorkomt een pilot die operationeel werkt maar niet op te schalen is.

Digitale en AR-werkinstructies beginnen meestal in de operatie. De plantmanager wil sneller inwerken, kwaliteit wil minder afwijkingen, onderhoud wil ondersteuning op afstand. De technologie wordt dan gekozen op gebruiksgemak. Securityvragen komen later, vaak op het moment dat een pilot een uitrol moet worden. Dat is het duurste moment om te ontdekken dat devices niet beheerd worden of dat video buiten de EU staat.

Dit dossier is geschreven voor de mensen die ja moeten zeggen tegen die uitrol: IT- en OT-managers, de CISO, de functionaris gegevensbescherming (FG) en de contactpersoon van de ondernemingsraad. Het beschrijft hoe een typische implementatie eruitziet, welke risico's reëel zijn en welke vragen u aan elke leverancier stelt, ook aan DeepSight, het platform dat ActARion implementeert.

Hoe een typische implementatie eruitziet

Onderdeel	Functie	Belangrijkste securityvraag
Auteursomgeving (browser)	Engineers en trainers maken en keuren instructies goed	Wie mag publiceren en is er een goedkeuringsspoor?
Player-app op tablet, telefoon of headset	Operator volgt stappen, maakt foto's, bevestigt controles	Is het device beheerd en kan het gewist worden?
Cloudplatform	Slaat instructies, media en uitvoeringslogs op	Waar staat de data en wie heeft toegang?
AI-diensten	Instructies opstellen uit documenten, video of audio; vertalen	Welke data gaat naar welk model en wordt die hergebruikt voor training?
Koppelingen (optioneel)	ERP/MES/CMMS, identity provider, LMS	In welke richting loopt data en met welke credentials?

Definitie: connected-worker-applicatie

Een connected-worker-applicatie is software die medewerkers op de werkvloer digitale werkinstructies, checklists en ondersteuning geeft op een mobiel of draagbaar device en vastlegt wat er is gedaan. Vanuit security bekeken is het een bedrijfsapplicatie met mobiele endpoints en persoonsgegevens, geen OT-systeem.

02 HOOFDSTUK 2

Hoe beheert u tablets, telefoons en AR-headsets?

Registreer elk device in mobile device management (MDM), gebruik een afgeschermd kiosk- of gedeeld-gebruikprofiel en beheer app- en firmware-updates centraal. Headsets verdienen dezelfde aanpak als tablets, ook al verschilt de MDM-ondersteuning per model.

Devices op de werkvloer worden gedeeld, rondgedragen, laten vallen en soms mee naar huis genomen. De basis is daarom strenger dan voor een kantoorlaptop. De meeste organisaties hebben al een MDM- of UEM-platform; het werk zit in het definiëren van een apart werkvloerprofiel.

Basisprofiel voor devices

- Device in MDM/UEM geregistreerd voordat het de lijn op gaat; geen persoonlijke registratie.
- Kiosk- of single-app-modus waar mogelijk, zodat alleen de instructie-app draait.
- Gedeeld gebruik met individuele login per dienst in plaats van één algemeen account.
- Schermvergrendeling, versleuteling en automatisch uitloggen bij inactiviteit.
- Camera- en microfoonrechten alleen voor de instructie-app.
- Vergrendelen en wissen op afstand getest, ook voor headsets.
- App- en OS-updates gefaseerd: eerst een testdevice, dan de lijn, buiten productiepieken.
- Fysieke labels en een assetregister, zodat een verloren device snel opvalt.

AR-headsets: wat is anders?

Head-mounted displays draaien vaak een eigen besturingssysteem en ondersteunen maar een deel van de MDM-functies. Vraag de leverancier welke MDM-platforms worden ondersteund, hoe firmware-updates worden verspreid en of ruimtelijke kaarten of scans van de ruimte op het device of in de cloud worden opgeslagen. Ruimtelijke data kan de indeling van een productiehal prijsgeven; sommige locaties beschouwen dat als vertrouwelijk.

Bring your own device (BYOD) is op de werkvloer zelden geschikt. Moeten externe monteurs of service-technici hun eigen telefoon gebruiken, beperk ze dan tot een afgeschermd app-profiel met gastcontent, zonder toegang tot interne instructies.

03 HOOFDSTUK 3

Hoe sluit u AR aan op het netwerk zonder OT te raken?

Zet werkvloerdevices op een eigen draadloos segment met toegang tot het platform, maar zonder route naar het besturingsnetwerk. Koppelingen met MES of CMMS lopen server-naar-server via de DMZ, nooit vanaf het device.

De meeste fabrieken werken met zones en conduits in de geest van IEC 62443 of het Purdue-model: bedrijfs-IT bovenin, een gedemilitariseerde zone (DMZ) in het midden en besturingssystemen (PLC, SCADA, DCS) onderin. Instructiedevices horen aan de IT-kant van die grens, ook al staan ze fysiek naast de machine.

01 **Maak een eigen SSID en VLAN**
Scheid werkvloerdevices van kantoorclients en van OT. Gebruik certificaatgebaseerde wifi-authenticatie (802.1X) in plaats van een gedeeld wachtwoord.

02 **Sta alleen toe wat de app nodig heeft**
Uitgaand HTTPS-verkeer naar de gedocumenteerde endpoints van het platform. Vraag de lijst met domeinen en poorten op bij de leverancier en zet ze op de allowlist.

03 **Blokkeer lateraal verkeer**
Geen routes van het device-VLAN naar PLC's, HMI's of engineering-werkstations. Ondersteuning op afstand mag geen achterdeur naar OT worden.

04 **Koppel in de DMZ**
Moet stapdata naar het MES of CMMS, gebruik dan een connector of middleware in de DMZ met een eigen serviceaccount en logging.

05 **Houd rekening met slechte dekking**
Controleer de wifi-dekking bij elke werkplek. Vraag of instructies offline beschikbaar zijn en hoe logs daarna synchroniseren.

Ondersteuning op afstand

Live videogesprekken met een expert elders zijn vaak de waardevolste en tegelijk de gevoeligste functie. Spreek af welke ruimtes gefilmd mogen worden, of sessies worden opgenomen, waar opnames staan en hoe lang ze bewaard blijven.

04 HOOFDSTUK 4

Welke data wordt opgeslagen en wat vraagt de AVG?

Foto's, video, audio en staplogs worden persoonsgegevens zodra ze herleidbaar zijn tot een medewerker. De AVG vraagt dan een grondslag, dataminimalisatie, vaste bewaartermijnen en, bij stelselmatige monitoring, een gegevensbeschermingseffectbeoordeling (DPIA).

Data-inventarisatie

Soort data	Voorbeeld	Persoonsgegeven?	Typische bewaarvraag
Instructiecontent	Stappen, 3D-modellen, referentiefoto's	Zelden (tenzij personen zichtbaar zijn)	Versiehistorie zolang het product wordt ondersteund
Uitvoeringslogs	Wie deed welke stap wanneer, duur, bevestigingen	Ja	Zolang nodig voor kwaliteitsherleidbaarheid
Bewijsfoto's	Foto van momentinstelling of label	Mogelijk (gezichten, pasjes)	Gekoppeld aan bewaartermijn van batch of werkorder
Video en audio	Ondersteuning op afstand, opnames voor AI	Ja	Standaard kort; alleen langer met reden
Accountgegevens	Naam, rol, taal, kwalificaties	Ja	Duur dienstverband plus vaste termijn
Ruimtelijke data	Scans, ankers	Meestal niet, wel mogelijk vertrouwelijk	Verwijderen bij wijziging van de lijn

DPIA: wanneer en hoe

Artikel 35 AVG verplicht tot een DPIA als een verwerking waarschijnlijk een hoog risico oplevert, in het bijzonder bij stelselmatige monitoring. Staplogs met tijdstempels per operator kunnen worden gebruikt

om prestaties te volgen. De meeste FG's vragen daarom om een DPIA, of minstens een vastgelegde toets. Doe dit tijdens het pilotontwerp, niet na livegang.

- Doel beschreven: werkinstructie, kwaliteitsherleidbaarheid, training; geen individuele prestatieranglijst.
- Grondslag vastgelegd (meestal gerechtvaardigd belang of wettelijke plicht voor herleidbaarheid).
- Dataminimalisatie: rapportage op team- of gepseudonimiseerd niveau waar namen niet nodig zijn.
- Bewaartermijnen per soort data, technisch afgedwongen.
- Verwerkersovereenkomst met de leverancier en lijst van subverwerkers.
- Doorgifte buiten de EER in beeld en afgedekt, of vermeden.
- Informatie aan medewerkers in begrijpelijke taal, in de talen die op de vloer gesproken worden.

Ondernemingsraad (en Betriebsrat in DACH)

In Nederland heeft de ondernemingsraad op grond van artikel 27 van de Wet op de ondernemingsraden (WOR) instemmingsrecht over regelingen voor personeelsvolgsystemen en over de verwerking van persoonsgegevens van medewerkers. Een systeem dat per persoon vastlegt wie welke stap wanneer uitvoerde, valt daar al snel onder. In Duitsland heeft de Betriebsrat medezeggenschap over technische systemen die geschikt zijn om gedrag of prestaties te controleren (§ 87 lid 1 nr. 6 BetrVG); geschiktheid is daar al genoeg.

In de praktijk legt u in een regeling vast welke data wordt verzameld, wie individuele data ziet, dat die niet wordt gebruikt voor individuele beoordeling tenzij afgesproken, en hoe medewerkers worden geïnformeerd. Een vroeg betrokken OR versnelt de uitrol meestal, omdat de acceptatie op de vloer beter is.

Hosting

Hostingregio van het platform: [EU-hosting: bevestigen]. Stel dezelfde vraag voor AI-diensten; die draaien soms in een andere regio dan het hoofdplatform.

05 HOOFDSTUK 5

Wat betekent de EU AI Act voor werkinstructies die AI opstelt?

AI gebruiken om werkinstructies op te stellen, te vertalen of samen te vatten is onder de EU AI Act doorgaans geen hoog-risicotoepassing. Relevant zijn transparantie, AI-geletterdheid en vooral een degelijke menselijke controle voordat een door AI opgestelde instructie de vloer bereikt.

De EU AI Act (Verordening (EU) 2024/1689) wordt gefaseerd van kracht. Verboden praktijken en AI-geletterdheid gelden sinds 2 februari 2025, regels voor AI-modellen voor algemene doeleinden sinds 2 augustus 2025. Sinds 2 augustus 2026 is de verordening algemeen van toepassing.

In 2026 heeft de EU de Digitale Omnibus voor AI aangenomen, die de hoog-risicotermijnen uitstelt. Deze is op 24 juli 2026 in het Publicatieblad verschenen. Verplichtingen voor zelfstandige hoog-risicosystemen uit bijlage III, waaronder AI voor werving en personeelsmanagement, gelden nu vanaf 2 december 2027. Voor hoog-risico-AI in gereguleerde producten (bijlage I) is dat 2 augustus 2028. De Omnibus herformuleerde ook het artikel over AI-geletterdheid: overheden ondersteunen die ontwikkeling, in plaats van een directe plicht voor aanbieders en gebruiksverantwoordelijken. Controleer de actuele richtsnoeren voordat u beleid vastlegt; uitvoeringsrichtlijnen verschijnen nog.

Waar AR- en AI-instructies passen

Toepassing	Waarschijnlijke classificatie	Wat te doen
AI stelt stappen op uit een handleiding of video; een engineer controleert en publiceert	Geen hoog risico	Menselijke controle, versiebeheer, AI-ondersteunde content intern markeren
AI vertaalt goedgekeurde instructies	Geen hoog risico	Controle door moedertaalspreker bij veiligheidskritische stappen
AI-assistent beantwoordt vragen uit goedgekeurde content	Meestal geen hoog risico; transparantie geldt	Vertel gebruikers dat ze met AI werken; beperk tot goedgekeurde bronnen
AI beoordeelt individuele prestaties of verdeelt taken	Mogelijk hoog risico (bijlage III, werk)	Buiten scope houden, of als apart project met juridische toets
Emotieherkenning van medewerkers	Verboden op de werkplek (met smalle uitzonderingen)	Niet gebruiken

Menselijke controle van AI-concepten

01 **Genereer als concept**
AI-output wordt altijd als concept opgeslagen, nooit direct gepubliceerd.

02 **Technische controle**
Een proces- of onderhoudsengineer controleert elke stap, tolerantie, aanhaalmoment en gereedschapsverwijzing tegen de bron.

03 **Veiligheid en kwaliteit**

HSE controleert waarschuwingen en PBM; kwaliteit controleert kritieke stappen en inspectiepunten.

04 **Goedkeuren en versioneren**

Goedkeurder, datum en versie worden vastgelegd. Eerdere versies blijven opvraagbaar.

05 **Valideren op de lijn**

Een ervaren operator voert de instructie één keer uit; bevindingen gaan terug vóór brede vrijgave.

Training van modellen op uw data

Vraag expliciet of uw documenten, beelden of video worden gebruikt om AI-modellen van de leverancier of derden te trainen, en of u dat kunt uitzetten. Leg het antwoord vast in het contract, niet alleen in een salespresentatie.

06 HOOFDSTUK 6

Is NIS2 van toepassing, en hoe passen identiteit en SSO erin?

Veel producenten, voedingsmiddelenbedrijven en energiebedrijven vallen onder NIS2, waardoor leveranciersbeveiliging een expliciete verantwoordelijkheid van het bestuur wordt. Single sign-on met rolgebaseerde rechten is de meest effectieve afzonderlijke maatregel voor een werkvloerplatform.

De NIS2-richtlijn (EU) 2022/2555 breidt cybersecurityverplichtingen uit naar middelgrote en grote organisaties in sectoren als energie, voeding, machinebouw, medische hulpmiddelen en chemie. Artikel 21 noemt de maatregelen, waaronder expliciet beveiliging van de toeleveringsketen, toegangsbeheer en multifactorauthenticatie. Nederland en België zetten de richtlijn om in eigen wetgeving (in Nederland de Cyberbeveiligingswet); stem de actuele status en uw positie af met uw juridische afdeling.

Voor een instructieplatform betekent NIS2 vooral dat u kunt aantonen dat u de leverancier hebt beoordeeld, dat toegang beheerst is en dat incidenten snel genoeg bij u gemeld worden om aan uw eigen meldplicht te voldoen.

Identiteit en toegang

- **SSO** via uw identity provider (SAML 2.0 of OpenID Connect) voor auteurs, goedkeurders en beheerders. Ondersteuning: [SSO-protocollen: bevestigen].
- **Multifactorauthenticatie** voor elke rol die content kan publiceren of wijzigen.
- **Operatorlogin** die past bij de vloer: pasje, QR-code of korte pincode op een beheerd device, gekoppeld aan een benoemde identiteit.
- **Rolgebaseerde rechten**: auteur, reviewer, goedkeurder, operator, beheerder, externe expert. Rechten per locatie en lijn.
- **Automatisch aanmaken en intrekken van accounts** (bijvoorbeeld SCIM), zodat vertrekkers dezelfde dag geen toegang meer hebben.
- **Auditlogs** van logins, publicaties en beheerwijzigingen, exporteerbaar naar uw SIEM.

07 HOOFDSTUK 7

Welke vragen horen in de securityvragenlijst voor leveranciers?

Gebruik een korte, specifieke vragenlijst over certificering, hosting, dataverwerking, AI, toegang, continuïteit en exit. Vraag om bewijs, niet om ja/nee-antwoorden.

De meeste organisaties hebben een standaard leveranciersvragenlijst. Onderstaande lijst voegt de vragen toe die specifiek zijn voor AR en AI op de werkvloer. ActARion helpt klanten deze antwoorden bij DeepSight op te halen en vast te leggen voor de FG en de OR.

- Informatiebeveiligingscertificering en scope: [ISO 27001: bevestigen].
- Hostinglocatie en subverwerkers voor platform, mediaopslag en AI-diensten.
- Versleuteling tijdens transport (TLS-versie) en in rust; sleutelbeheer.
- Meest recente onafhankelijke penetratietest, scope en status van opvolging: [pentest: datum en scope bevestigen].
- Ondersteunde MDM-platforms en headsetmodellen; gedrag zonder verbinding.
- SSO, MFA, SCIM en rollenmodel; export van auditlogs.
- Bewaarinstellingen per soort data; verwijderen op verzoek en bij einde contract.
- Gebruik van klantdata voor modeltraining; opt-out; welke AI-modellen en waar die draaien.
- Goedkeuringsworkflow en versiebeheer voor AI-content.
- Termijn en contactpunt voor incidentmeldingen; afstemming op NIS2- en AVG-meldtermijnen.
- Continuïteit: beschikbaarheidsdoel, back-ups, hersteltests.

- Exit: exportformaat voor instructies, media en logs.

Een praktische volgorde

01 **Week 1: scope**
Bepaal pilotlijn, type device, te verzamelen data en koppelingen. Nodig IT/OT, FG en OR-contactpersoon uit.

02 **Week 2–3: beoordeling**
Vragenlijst leverancier, DPIA-toets, netwerkontwerp, MDM-profiel.

03 **Week 3–4: afspraken**
Verwerkersovereenkomst, instemmingsaanvraag bij de OR, interne procedure voor AI-controle.

04 **Pilot**
Draai met de afgesproken maatregelen; leg securitybevindingen vast naast de operationele KPI's.

05 **Besluit over uitrol**
Bevindingen bespreken, maatregelen bijstellen, daarna per locatie opschalen.

0	100%	1 dag
routes van device-VLAN naar het OT-besturingsnetwerk	van AI-concepten gecontroleerd door een benoemde goedkeurder	streeftermijn voor intrekken van toegang bij vertrek

?

Veelgestelde vragen

Is AR op de werkvloer een OT-securityrisico?

Niet als het goed is ontworpen. Instructiedevices hebben content uit een bedrijfsapplicatie nodig, geen toegang tot besturingssystemen. Zet ze op een apart netwerksegment zonder routes naar PLC's of SCADA en laat koppelingen met MES of CMMS server-side via de DMZ lopen.

Is een DPIA nodig voor digitale werkinstructies?

Vaak wel, of minstens een vastgelegde toets. Staplogs die herleidbaar zijn tot operators kunnen worden gebruikt om prestaties te volgen, een typische aanleiding voor een DPIA onder artikel 35 AVG. Uw FG beslist; doe het tijdens het pilotontwerp.

Heeft de OR instemmingsrecht?

Meestal wel. Artikel 27 WOR geeft de ondernemingsraad instemmingsrecht over personeelsvolgsystemen en de verwerking van persoonsgegevens van medewerkers. Betrek de OR vroeg en leg de afspraken over datagebruik vast.

Zijn door AI opgestelde werkinstructies hoog-risico onder de EU AI Act?

Doorgaans niet, als AI alleen concepten of vertalingen maakt die mensen controleren en goedkeuren. AI die individuele medewerkers beoordeelt of aanstuurt kan onder bijlage III vallen; die verplichtingen gelden na de Digitale Omnibus vanaf 2 december 2027.

Kan het platform in de EU gehost worden?

Dat moet per leverancier en per onderdeel worden bevestigd, inclusief AI-diensten. ActARion haalt deze informatie voor DeepSight op tijdens de intake.

BRONNEN

1. Verordening (EU) 2024/1689 (AI-verordening), EUR-Lex — https://eur-lex.europa.eu/eli/reg/2024/1689/oj
2. Future of Privacy Forum: The AI Act implementation timeline – what changes under the AI Omnibus? — https://fpf.org/blog/the-ai-act-implementation-timeline-what-changes-under-the-ai-omnibus
3. Sidley Data Matters: EU lawmakers reach provisional agreement to delay key EU AI Act obligations — https://datamatters.sidley.com/2026/06/22/eu-lawmakers-reach-provisional-agreement-to-delay-key-eu-ai-act-obligations/
4. Verordening (EU) 2016/679 (AVG), EUR-Lex — https://eur-lex.europa.eu/eli/reg/2016/679/oj
5. Richtlijn (EU) 2022/2555 (NIS2), EUR-Lex — https://eur-lex.europa.eu/eli/dir/2022/2555/oj
6. Wet op de ondernemingsraden (WOR), wetten.overheid.nl — https://wetten.overheid.nl/BWBR0002747
7. Betriebsverfassungsgesetz § 87 Mitbestimmungsrechte — https://www.gesetze-im-internet.de/betrvg/__87.html

ActARion



Plan een kosteloze intake

Wilt u uw securitybeoordeling, DPIA en OR-traject voorbereiden voordat een pilot start? Plan een kosteloze intake met Jack Kessels (Benelux) of Mark Dercksen (DACH). Wij brengen de antwoorden van de leverancier en een beproefde pilotopzet mee.

Plan een kosteloze intake **Bereken uw ROI**

Jack Kessels · Benelux Mark Dercksen · DACH hello@actarion.com

© 2026 ActARion. Deze whitepaper is algemene informatie, geen juridisch of financieel advies.